

Application	• User ID/Password Sniffing
Presentation	• SSL/TLS Session Sniffing
Session	• Telnet and FTP Sniffing
Transport	• TCP Session Sniffing, UDP Sniffing
Network	• IP, Port Sniffing
Datalink	• MAC / ARP Sniffing
Physical	• Surveillance Sniffing

Figure 1. Mapping of OSI layers

sniffing, wide usage of wireless networks has made it easy to sit near the network and penetrate it to get information.

Regardless of where the hackers are located on the network being sniffed, they use packet capturing or packet sniffer software. Modem packet sniffers are supposed to be used for troubleshooting network problems, but can be used for hacking too. Please refer to Figure 3, which depicts the ethical and unethical side of sniffer software.

Regarding the technical details of how sniffing is done, we need to remember that packet capturing software always runs in promiscuous mode, whereby it is capable of intercepting and storing all packets on a network. This also means that, even though the packet is not meant for the network interface on which the sniffer is running, it is captured, stored and analysed. Sniffer software contains its own network driver and buffer memory in order to capture a large chunk of packets. Modern sniffers are capable of analysing the captured packets and converting them into sensible statistical information. Now let's discuss a few ways of sniffing a network, to understand how hackers get what they want.

A LAN sniff

A sniffer deployed on an internal LAN can scan the entire IP range promiscuously. This helps in providing further details such as live hosts, open ports, server inventory, etc. Once a list of open ports is gathered, a port-specific vulnerability attack is possible.

A protocol sniff

This method involves sniffing data related to the network protocols being used. First, a list of protocols is created based on the captured data. This is further segregated to create special sniffers for each attack. For example, in a network sniff capture, if the ICMP protocol is not seen, it is assumed to be blocked. However, if UDP packets are seen, a separate UDP sniffer is started to capture and decipher Telnet, PPP, DNS and other related application details.

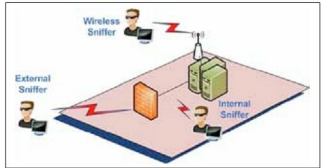


Figure 2. Sniffing attack vectors

Sniffer Tool Usage	
Ethical Usage	Un-Ethical Usage
Packet Capturing	Userid and password stealing
Network Traffic Usage and Analysis	Email or instant message data stealing
Packet conversion for data analysis	Packet spoofing and data theft
Network troubleshooting	Monetary or reputational damage

Figure 3. Ethical vs unethical sniffing

An ARP sniff

In this popular method, the hacker captures a lot of data in order to create a map of IP addresses and the associated MAC addresses. Such a map is further used to create ARP poisoning attacks, packet-spoofing attacks, or to dig into router-based vulnerabilities.

TCP session stealing

This method is a very basic form of sniffing, in which a network interface in promiscuous mode captures traffic between a source and a destination IP address. Details such as port numbers, service types, TCP sequence numbers and the data itself are of interest to hackers. Upon capturing enough packets, advanced hackers can create fabricated TCP sessions to fool the source and destination, and be the man in the middle to take over the TCP session.

Application-level sniffing

Usually, from the data packets sniffed and captured, a few intricate application details are found out for information stealing or to create further attacks. As an example, the capture file can be parsed to perform OS fingerprinting, SQL query analysis, reveal application-specific TCP port data information, etc. In another approach, creating a mere list of applications running on a server is good enough to plan an application-specific attack on it.

Web password sniffing

As the name suggests, HTTP sessions are stolen and parsed for user ID and password stealing. While the Secure Socket Layers (SSL) are incorporated for securing HTTP sessions on the network, there are numerous internal websites that still use standard but less secure encryption. It is easy to capture Base64 or Base128 packets and run a deciphering agent against it to crack the password. In modern sniffers, SSL sessions can also be captured and parsed for information, though this method is not very easy.